

2026

Perform Threat Hunting Against 5 Machines

MOSSÉ CYBERSECURITY INSTITUTE

Student ID: 24niZSZPvqYEcB53AUYPe2z4w9X2

Table of Contents

Executive Summary..... 3

Investigation Approach..... 3

Compromised Machines..... 5

Indicators of Compromise (IOCs)..... 6

Recommendations..... 7

Limitations and Constraints..... 8

Assumptions..... 8

Executive Summary

During this threat-hunting investigation, forensic triage data collected from five Windows machines — hostnames CRW167SL, PXA949WW, RDL208NS, RDL794WW, and UMI895SB — was analyzed to identify the two machines showing evidence of compromise. The datasets, covering domain users, logged-on users, local/domain user accounts, running processes, services, drivers, and persistence artifacts (registry and file items), were loaded into Pandas dataframes and reviewed systematically across the entire fleet for anomalous privileged accounts, processes executing from non-standard paths, and services or persistence mechanisms that did not match their expected, legitimate configuration.

The investigation found that two hosts, CRW167SL and PXA949WW, each contain a locally-created administrator account with a randomly generated, domain-disconnected username — a pattern found nowhere else across the five-host fleet and inconsistent with the organization's normal account-naming convention. CRW167SL additionally shows direct evidence of service masquerading: a legitimate-looking Windows driver service (hidinterrupt) was found repointed to a script file in a world-writable folder, confirmed by comparing it against the same service's genuine configuration on PXA949WW. The remaining three hosts (RDL208NS, RDL794WW, UMI895SB) were checked against every one of these indicators and showed no equivalent anomalies. Identifying these two machines matters because both carry a persistent, attacker-controlled path to full administrative control that would survive a simple password reset, and because the shared technique across both hosts suggests a single actor or toolkit was responsible, making a coordinated containment and recovery response important.

Investigation Approach

Forensic triage data for all five machines was collected in a format consistent with FireEye Redline endpoint analysis exports, covering Domain Users, Logged On Users, User Accounts, Windows Drivers, Windows Persistence File Items, Windows Persistence Registry Items, Windows Persistence Service Items, Windows Processes, Windows Services, and Windows Tasks. Each category was exported as Parquet and loaded into Pandas dataframes inside a Jupyter Notebook for structured, repeatable analysis.

Because five hosts had to be triaged rather than two, the investigation plan started broad and narrowed quickly: fast, fleet-wide filters were run first to try to replicate known attack patterns (SYSTEM processes launched from user folders, execution from Temp/AppData/WindowsApps), and when those came back clean, the plan pivoted to a full privilege audit of every local and domain account on every host, which is what surfaced the two backdoor accounts. Table 1 summarizes the categories of data reviewed and the common IOCs associated with each; Table 2 maps typical attacker techniques to the data categories and terms used to hunt for them.

Table 1: Categories of Data and Common Indicators of Compromise

Category	Common Indicators of Compromise (IOCs)
Domain Users	Unusual or unknown domain accounts Elevated privileges granted to an account (admin/system-level access) Accounts with weak or reused passwords
Logged On Users	Users logged in from multiple hosts (possible lateral movement) Accounts active at unusual times or in unexpected contexts A privileged account active on a standard workstation

User Accounts	Local accounts with no domain identity holding local-admin rights Randomly-named or non-descriptive accounts (backdoor pattern) Accounts that mimic legitimate service/process names
Windows Drivers	Unsigned or suspicious drivers Drivers loaded from non-standard paths Newly installed or unexpectedly modified drivers
Windows Persistence — File/Registry Items	Unusual files in persistence-related or world-writable directories (e.g. C:\Public) Registry entries pointing to non-legitimate executables
Windows Services	A legitimate-sounding service pointed at a non-standard file type (masquerading) Services running from suspicious paths Mismatched file hash/signature versus a known-good baseline of the same service
Windows Processes	Processes running from non-standard, user-writable paths (Temp, AppData, ProgramData, WindowsApps) A process running with more privilege than expected for its context
Windows Tasks	New or hidden scheduled tasks Tasks configured to run non-standard executables or commands

Table 2: Attack Types Mapped to Categories and IOC Terms

Attack Type	Category	Example IOC Terms
Local backdoor account creation	User Accounts, Domain Users	local-admin=True with domain-user=False, random/non-convention usernames
Service masquerading for persistence	Windows Services, Persistence Registry/File Items	ImagePath/service target pointing to .vbs/.ps1/.bat instead of a compiled binary, mismatched MD5 vs. a known-good copy of the same service
Malicious Windows commands	Windows Processes, Windows Services	cmd.exe, powershell.exe, wmic, sc, rundll32, mshta
Execution from a user-writable / masquerading path	Windows Processes, Persistence File Items	AppData, Temp, ProgramData, WindowsApps, C:\Public, non-standard script extensions
Domain-admin credential misuse	Logged On Users, Domain Users	Administrator or other domain-admin accounts logged onto an unexpected workstation
Path interception	Persistence Registry Items, Windows Services	%SystemRoot%, unquoted service paths

Compromised Machines

This section explains why hosts CRW167SL and PXA949WW are assessed as compromised.

The Domain Users dataset identifies the environment's baseline: the sanfrancisco group holds the everyday employee accounts (mat.sco, flet.lee33, maddi.campbel8, ricwood), while domain admins contains mat.sco, Administrator, and svc_em. mat.sco is legitimately a member of both groups, which establishes the normal power-user pattern for this organization and is not, by itself, an anomaly.

In [16]:

```
user_accounts[user_accounts['username'].str.contains(
    'zBMI|dEkS', case=False, na=False)]
```

	domain-admin	domain-user	hostname	local-admin	local-user	username
3	False	False	CRW167SL	True	True	zBMIAhqYKPEfTT
8	False	False	PXA949WW	True	True	dEkSarQLRvDfhPA

Figure 1: Two locally-created administrator accounts isolated by their random-string usernames

Every legitimate account in this environment (mat.sco, ricwood, flet.lee33, maddi.campbel8, elijgonzal, evebail, dani.robi52, amber.hill, darcieprice) follows a recognizable firstname.lastnameNN naming convention and is tied to the domain (domain-user = True). The two accounts above, zBMIAhqYKPEfTT and dEkSarQLRvDfhPA, break that pattern completely: both are random alphanumeric strings, both hold local-admin = True, and both have domain-user = False and domain-admin = False, meaning they are not tied to any domain identity at all. Each appears on exactly one host — a strong, low-false-positive signature of an attacker-created local backdoor account.

On CRW167SL, a second and independent line of evidence was found in the Windows Services dataset: the hidinterrupt service, which should be a genuine Windows kernel driver, has been repointed to a script file.

In [19]:

```
for h in ['CRW167SL', 'PXA949WW']:
    print(f"=== {h} — Services ===")
    print(services[services['hostname'] == h].to_string())
```

CRW167SL		name: hidinterrupt		type: SERVICE_KERNEL_DRIVER
		path: C:\\Public\\run.vbs		
		md5: e7311e22f0d28d15d7f4b489bdc5c752		
		descriptivename: Common Driver for HID Buttons implemented with interrupts		
PXA949WW		name: hidinterrupt		type: SERVICE_KERNEL_DRIVER
		path: C:\\Windows\\System32\\drivers\\hidinterrupt.sys		
		md5: 365cf57198f5e4c24fd2fc2a5450a794		
		descriptivename: Common Driver for HID Buttons implemented with interrupts		

Figure 2: Side-by-side comparison of the hidinterrupt service on CRW167SL vs. PXA949WW

Both hosts have a service with the identical name and description ("Common Driver for HID Buttons implemented with interrupts"), but on CRW167SL its target is C:\\Public\\run.vbs — a VBScript file in a non-standard, world-writable folder — rather than the genuine compiled driver (hidinterrupt.sys) found in the same slot on PXA949WW, and the file hash on CRW167SL does not match the legitimate driver's hash. This is a classic service-masquerading persistence technique: reusing a trusted-sounding, low-attention service name so that a malicious script runs (or can be triggered to run) under the guise of routine driver activity.

The remaining three hosts, RDL208NS, RDL794WW, and UMI895SB, were checked against the same account-privilege audit and showed no locally-created admin accounts and no equivalent service anomalies. One secondary observation — the Administrator domain-admin account logged on to RDL794WW — was investigated separately and is discussed in the Assumptions section.

Host	Finding	Assessment
CRW167SL	Local admin account zBMLahqYKPEfTT (no domain identity) + hidinterrupt service repointed to C:\Public\run.vbs	Compromised
PXA949WW	Local admin account dEkSarQLRvDfhPA (no domain identity), same naming pattern	Compromised
RDL208NS	No anomalous accounts, processes, or services found	Not compromised
RDL794WW	Administrator domain-admin logon observed (assessed as legitimate — see Assumptions); otherwise clean	Not compromised
UMI895SB	No anomalous accounts, processes, or services found	Not compromised

Indicators of Compromise (IOCs)

Before the two account/service findings above were isolated, several fast, high-signal checks that worked in a previous, similar investigation were repeated across all five hosts to see if the same technique had been reused.

```
In [8]:
system_procs[system_procs.astype(str).apply(
    lambda row: row.str.contains(r'Users\\', case=False, na=False)
).any(axis=1)]

Empty DataFrame
Columns: [arguments, hostname, name, path, pid, username]
Index: []
```

Figure 3: No SYSTEM process was found executing from inside a user profile folder, on any host

This came back clean on every host, as did a similar search for process execution from Temp/AppData/ProgramData/WindowsApps (every hit there was a legitimate, per-user application such as OneDrive or GitHub Desktop). These negative results were useful: they showed the compromise on CRW167SL and PXA949WW used a different technique than SYSTEM-level script execution, and pointed the investigation toward the account and service audit that ultimately found the real evidence.

IOCs Explained in Plain Language

The technical evidence above can be summarised in everyday terms for readers who are not familiar with threat hunting or digital forensics:

A stranger's keycard was found with full building access, but no ID badge to match.

Every real employee here has an ID badge that matches a name in the company directory (like mat.sco or ricwood). zBMlahqYKPEFTT and dEkSarQLRvDfhPA are keycards that open every door (local administrator rights) but don't match anyone in the company directory at all — like finding a master keycard with a random serial number instead of a name. That's exactly the kind of thing someone breaking in would leave behind so they can walk back in later.

A trusted maintenance worker's badge was quietly swapped for someone else's task list.

hidinterrupt is a small, routine piece of software — like a maintenance worker whose only job is to keep one device's buttons working. On CRW167SL, someone swapped that worker's real instructions for a different, unofficial note left in a public mailbox (C:\Public) that anyone can drop something into. On PXA949WW, the same worker still has their real, original instructions. Comparing the two side by side is how we know CRW167SL's version was tampered with — it's the digital equivalent of catching a badge with the right name on it, but the wrong photo and no security stamp.

We double-checked the usual suspects and they came back clean.

In an earlier, similar investigation, attackers had used a 'system-level shortcut' trick to run their own hidden script. We checked every one of these five machines for that exact same trick and found nothing — which matters because it tells us this particular attack didn't reuse that old method, and it's why the account and service checks above ended up being the real breakthrough rather than a lucky first guess.

Recommendations

A priority recommendation is to isolate CRW167SL and PXA949WW from the network to prevent further use of the backdoor accounts or the masquerading service. Both should be preserved (memory and disk image) before remediation, since the hidinterrupt/run.vbs artifact on CRW167SL should be extracted and analyzed to determine the script's full behaviour and any command-and-control it may reach out to.

The local administrator accounts zBMlahqYKPEFTT (CRW167SL) and dEkSarQLRvDfhPA (PXA949WW) should be disabled immediately, not just password-reset, since they are not legitimate accounts at all. The genuine hidinterrupt driver should be restored from a known-good source on CRW167SL and the service's file hash re-verified against Microsoft's published baseline.

A fleet-wide audit of local administrator group membership should be run on every endpoint (not just these five) to check for the same random-username backdoor pattern elsewhere, since the identical technique on two separate hosts suggests a repeatable script or toolkit rather than a one-off manual action.

Service integrity monitoring should be deployed so that any service's target executable/script and file hash are automatically compared against a known-good baseline, flagging drift the way the hidinterrupt comparison did here manually. Application allow-listing (AppLocker/WDAC) should also be used to block script execution (.vbs, .ps1, .bat) from world-writable folders such as C:\Public.

Both machines should be rebuilt from a known-good image rather than manually cleaned, given that local administrator-level persistence was established. Passwords for legitimate accounts that were active on these two hosts (mat.sco, ricwood, and others per the process listings) should be rotated as a precaution, and a Security Information and Event Management (SIEM) platform with centralized service-change and local-account-creation alerting should be implemented to catch this pattern automatically in the future.

Limitations and Constraints

The datasets provided did not include reliable event timestamps, which prevented building a precise timeline of when the two backdoor accounts or the masqueraded service were created.

The registry and file persistence query for CRW167SL and PXA949WW was interrupted mid-run by a Jupyter “IOPub data rate exceeded” limit, which caused the registry-persistence results and the CRW167SL file-persistence results to be dropped from the notebook’s output before they could be reviewed; only the tail of PXA949WW’s file-persistence listing survived. This is a genuine gap — a full persistence-artifact review for CRW167SL, and the registry-persistence review for both hosts, could not be completed with the data captured in this run.

Neither zBMLahqYKPEfTT nor dEkSarQLRvDfhPA appeared in the logged-on-users table at collection time, so this dataset alone cannot confirm whether or when the backdoor accounts were actively used — only that they exist and hold local admin rights.

No network telemetry (DNS, proxy, firewall, or netflow logs) was available, so it was not possible to confirm whether C:\Public\run.vbs made any outbound connection, downloaded further payloads, or exfiltrated data.

Only five endpoints were provided for this investigation, with no Active Directory or domain-controller-level logon data available to confirm whether either backdoor account, or the technique used to create them, appeared anywhere else in the broader environment.

Scheduled tasks (up to 145 per host) and the full driver listing were not exhaustively reviewed line-by-line for every host; the investigation prioritized the account and service findings once they were identified as the strongest signal.

Assumptions

It is assumed that the forensic artifacts (Parquet exports) accurately reflect the state of each host at the time of collection and were not altered between collection and analysis.

The single Administrator domain-admin logon observed on RDL794WW is assumed to be legitimate administrative activity rather than an IOC, since Administrator is a confirmed member of the domain admins group in the Domain Users baseline and no other corroborating evidence (anomalous account, process, or service) was found on that host. This assumption should be revisited if additional evidence emerges.

Because mat.sco’s domain and local admin privileges are consistent with membership in both the sanfrancisco and domain admins groups, this is assumed to be the pre-existing, legitimate baseline for that account rather than an IOC in itself.

It is assumed that zBMLahqYKPEfTT and dEkSarQLRvDfhPA are not legitimate, sanctioned local accounts (e.g., for a vendor or support tool) that simply happen to use randomized names; this assumption is based on the absence of any domain tie, description, or comparable account elsewhere in the fleet, but it should be confirmed with the system owners before final remediation.

It is assumed that the genuine hidinterrupt.sys driver observed on PXA949WW represents the correct, unmodified baseline for that service across the fleet, and that CRW167SL’s version is the outlier rather than the reverse.

The investigation assumes the collected artifacts represent a single point-in-time snapshot; no assumption is made about whether the compromise was ongoing, contained, or fully remediated at the time of collection.